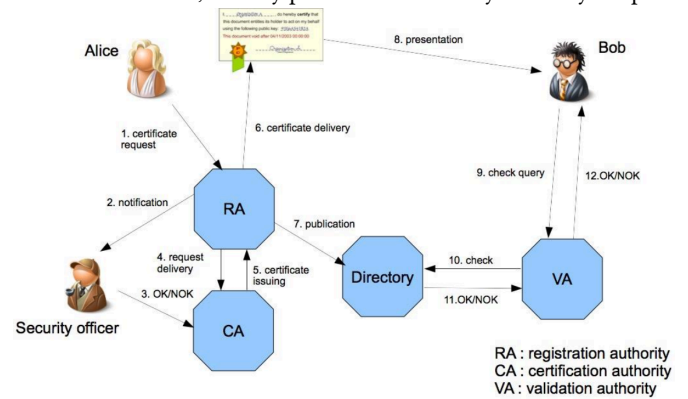


IT Focus data mgmt, confidentiality. **Operational Technology (OT) Focus:** physical processes, availability/safety. Stricter uptime/deterministic requirements (real-time operations). Involve critical sys w/ severe physical consequences. **Challenge:** skill gaps + miscommunication IT/OT **CS Threats:** Malware, Ransomware, Advanced Persistent Threats (stealthy/continuous hacking), Insider Threat. **How to secure:** ntw segmentation (Separation of OT&IT), limit threat lateral movement, reduce risk unauthorized access, defense-in Depth strat, access ctrl, secure communication. **IT vs OT constraints:** Technology support lifecycle (IT: 2-3yrs, many suppliers; OT: 10-20yrs, few suppliers => legacy sys are strong issue). Patching strat (IT: automated/regular; OT: long delay, strong planification, can strongly impact business continuity). Test&audit (IT: usually automated; OT: customized solutions, critical nature often requires offline testing). Asset classification (IT: yearly; OT: on-demand only, lack of asset supervision). Incident-response&forensics (IT: legally required; OT: usually just sys reboot, forensics not really addressed). Physical sec (IT: low in offices, high in datacenters; OT: usually high, dedicated building/rooms). Secure SW development (IT: sec integrated by design; OT: historically isolated so not considered by-design, add-on sec layers are complex to integrate later). End-point sec (IT: easy to deploy/manage remotely; OT: limited performance/realtime/memory footprint, custom solutions exist but are complex to manage). **Industrial Ctrl Sys (ICS)** Inf sys to ctrl industrial processes. Includes SCADA. **Sec Challenge:** Legacy protocol/sys => isolation/segmentation; limited visibility/patch mgmt => enhance visibility; convergence IT/OT => securing external connection, supply chain risks/human error => access ctrl&containing incident spread. **Distributed Ctrl Sys (DCS)** ICS architecture where ctrl is distributed between entities. **Supervisory Ctrl&Data Acquisition (SCADA)** ctrl/gather/process data from ctrl geographically dispersed assets. **Programmable Logic Controller (PLC)** Programmable industrial computer that executes user-defined logic for I/O ctrl, timing, counting, PID regulation, communication. **Legacy OT** lvl 0/1 devices: long lifecycle (10-20+ yrs), ruggedized/fanless/low-power, harsh conditions, strict SLA. Hard to patch/update => vuln accumulation. **Risk** Effect of uncertainty on obj. **Mgmt:** Must be repeatable, scalable&transferable. Identify risk => compare to org accepted risk threshold => avoid/transfer/mitigate/accept. **Purdue Model (PERA)** outlines interaction IT/OT. Enable better comm. IT/OT. Aims to reduce risk of threats. **Ivl0:** instrument to sensing /acting on physical process (sensors, pumps, valves). **Ivl1:** intelligent device to sense/monitor/ctrl physical process (PLC, SIS, RTU). **Ivl2:** ctrl sys to supervise/monitor physical process (HMI, SCADA). **Ivl3:** operation sys to manage/ctrl production flow (AD, File srv, Historians). **DMZ:** buffer btwn ICS/external ntw (Proxy, Mail, Replica). **Ivl4:** enterprise ntw (data exchange, business-to-business, business-to-client). **Governance Hierarchy** External/internal influence => **Policy** (high lvl declaration = why) => **Control** obj (obj of policy) => **Standard** (what to do to apply policy, mandatory) => **Guideline** (recommended way to meet standard, optionnal) => **Control** (implementation of standard) => **Procedure** (how to implement ctrl). Risks/Threats justify ctrl; Metrics measure ctrl effectiveness. **Standardization Goals:** Maximize business benefits, institutionalize best practices in standards, be compliant (contract obligations, laws, regulation). **Benefits:** ensure fulfillment of necessary quality, preferred access to market, defines obligations, give guarantees. **Standard vs Certification Standard:** document describing best way of doing something (IEC, NIST, IEEE, ISO). **Certification:** written assurance by an independent body that specific requirements (a standard) are met. **Critical Infrastructure** Not the same btwn USA/UE/CH. Energy (gas/power/oil supply), Finances, Inf&Communication (media, postal, telecom), Public Administration (government, justice, reasearch), Pulic Health (hospital, laboratory), Public Safety (army, emergency services), Transport (air, rail, road), Food&Water, Waste disposal. **Impact of regulations on OT Obligations:** Policies on risk analysis&inf sys sec, incident handling, business continuity (backup mgmt/disaster recovery/crisis mgmt), supply chain sec, sec in ntw&inf sys (acquisition/development/maintenance/vuln handling&disclosure), Policies&procedures to assess effectiveness of cs risk-mgmt measures, basic hygiene practices&cs training, policies&procedures regarding use of cryptography, human resources sec, access ctrl policy, asset mgmt, use of MFA&secured emergency communications, coordinated vuln disclosure policy. **Impact:** fines up to 2% global revenue. CH: Criminal Code (data theft/unauthorized access/data damage/computer fraud). **Role of communication sys Goals:** Facilitate inf flow to improve operations efficiency. Enhance better decision making w/ real-time data. Promote operational continuity w/ reliable communication sys. **Requirement:** determinism/real-time/scalability/reliability/availability/latency/time sync/open standards/interoperability/sec. **Why real-time:** needed for timely/accurate data processing/ctrl actions/precision/rapid response. **Quality Of Service (QoS):** prioritize ntw traffic (critical data first)/minimize delay/maintain operational efficiency&productivity. **RTOS:** combined w/ comm ensure efficient task mgmt, rsc allocation, real-time perf. **WAN Requirement:** deterministic end-to-end perf (no best effort), guaranteed QoS/delay/jitter, precision time&clock, encrypted packet, fast path protection switching. **Encryption/Network Segmentation:** need for data protection against breach/unauthorized access. Access limitation to reduce risk&enhance sec posture. **Use of Secure Protocols:** to ensure privacy/integrity, prevent eavesdropping. **Heterogeneity of OT Sys:** variety of device w/ unique specs&fct, protocols => Interoperability Challenge. **Open Standard:**

ensure interoperability, facilitate communication, enhance data exchange. **Communication Protocol Classification** External (protocol relies on external sec measure ?), Msg integrity ? Msg confidentiality ? Secure Authentication&Authorization ? **OT Wired Communication** Favored for their high-speed/stable capabilities (crucial for real-time data). **Ethernet:** non-time-critical comm btwn lvl1&lvl2. **FieldBus:** wired protocol to link lvl0&lvl1. time critical/cost requirement **MODBUS:** client-srv/master-slave arch w/ limited computing rsc. **simplicity/interoperability/cost-effectivness/flexibility/wide adaption. limited bandwidth/no built-in sec/redundancy/limited error handling/addr space/no support complex data/polling overhead/no safety/real-time** **EtherCAT:** real-time ethernet, topology agnostic, support for 2¹⁶ devices, sync w/ distributed clocks. **real-time comm/cost-efficiency/scalability/flexible topology/high reliability. complex ntw design/device compatibility/integration/debugging** **OT Wireless Communication:** Flexibility&Mobility (no physical constraint). Need careful implementation to mitigate interference/risks. **Critical factors:** Limited energy capacity/HW constraints/Dynamic ntw/Node deployment/Fault tolerance/Latency/Data aggregation/Scalability. **Zigbee:** mesh WPAN. Roles: Coordinator(ZC) (first started node, form ntw, allow other node to join ntw, unique), Router(ZR) (routing, multiple), End device(ZED) (send/receive only, can be sleepy). **low power/low cost/scalable/128-bit sym key. low data rate/short range.** **WirelessHART:** bi-directional industrial field communication btwn host sys&field device. Provides 2 simultaneous channels (analogue, digital). Roles: Field device, Gateway (bridge to host/backbone), Network Manager (schedules comm, routes, monitors health). **low power/scalable/time sync/TDMA/redundant transmission/frequency hopping. mid-range only.** Sec: end-to-end encryption (128-bit AES)/unique key/message/rotating join keys/common ntw key for broadcast/join key = device authentication. **Others:** 5G, Wi-Fi. **SyncE** derives clock sync from physical-layer signal edges. **PTP** GPS-based grandmaster sends timestamped packets to sync slave clocks. **Time Sensitive Network (TSN)** Deterministic data transmission. Suitable for industrial automation application. Time sync btwn devices => ensure data transmission over defined time parameters. Allow allocation/priorization of ntw bandwidth. Enhance reliability => minimize packet loss/latency. Interoperability w/ existing Ethernet standards. **Guard Band:** blocks new low-priority frames just before critical time slot, so no frame overruns into it. $G_size\ [\mu s] = \frac{max\ frame\ size\ [bytes]}{link\ rate\ [Mb/s]}$. **Air-Gapped** No physical link OT/IT (extreme segmentation). **threat mitigation/compliance/data integrity. infra cost/insider threat still possible/hard to update/maintain.** **Multi Protocol Label Switching (MPLS)** Faster than IP routing. Data transport protocol based on labels, layer 2.5. Link ip addr to label (FEC). Allow various app (VPN, traffic aggregation, QoS). Use Label Swapping Table. **LSP:** path through ntw = sequence of labels, each LSR swaps label, "tunnel" w/o inspecting inner header. **LSR:** core router, high-speed label swapping. **LER:** ntw edge, push/pop label (IP<=>MPLS), assign FEC. **Flow:** LER push label => LSR swap => ... => LSR swap => LER pop label (back to ip). **Intrusion Detection/Protection Sys (IDS/IPS)** monitor network to allow real-time suspicious activity detection => immediat response. **Network-based:** monitor traffic on ntw segment. **Host-based:** monitor local logs/files/processes/traffic on single host. **Hybrid:** combine both ntw+host view. **Behavioural:** detect deviation from learned normal behavior (anomaly-based). **Warning: acting on identified threat can impact production.** **Zero Trust** All data/computing services = rsc. No implicit trust based on ntw location, secure every comm. Access granted per-session, via dynamic policy (behavioral/environmental attributes). Authentication/authorization strictly enforced, re-checked dynamically. Continuously monitor asset/ntw integrity to improve sec posture. **Open Platform Communications Unified Architecture (OPC UA)** standard for industry 4.0 convergence (cyber, physic, human, logistic, sell, etc.). Standardized access to all components, Manufacturer-independent data exchange, platform independent. Rich/extensible info model (complex types). **state of art native sec, support** (vs Modbus: no native sec). **Modes:** Client-Srv, Publisher-Subscriber (PubSub). **IEC 61850** standard for defining devices w/i substation automation sys&how their interactions. **Platform for:** comm, protection, ctrl, automation, measurements, recording, monitoring. **Features:** self description (interrogation), fast peer-to-peer (tripping/blocking/interlocking), reduce hard-wired connections, reporting. **Standardizes:** design, language, services, protocol, config, substation/device info, naming convention, fault records, conformance tests. **Protocols:** MMS, GOOSE, Sampled Values (SV). **Product Life-Cycle Management (PLM):** Ensure that every involved person has access to inf about all process. **1) Idea:** New ideas based on market research. Creative/Structured phase to determine if product can succeed => Understanding client needs&market trends. **2) Design:** Detail specifications, plans&prototypes. Ensure its functional&feasable. Need versionning => Make product appealing **3) Manufacturing:** Design to product. Include sourcing materials, setting up production lines, quality ctrl. Design data is integrated to manufacturing process to keep errors low&improve efficiency => Ensure data meets brand promise&quality standards **4) Service&Maintenance:** Distribution, customer services, maintenance. track product perf&customer feedbacks to improve product => Ensure customer satisfaction&enable longer product lifespan. **5) Disposal:** Safe/responsible disposal/recycling. According to regulations&sustainability practices. **Product CS Lifecycle Secure Product Development:** Secure Product => Sec Planning&Classifi-

cation => Threat Modeling&Risk Assessment => Sec Requirements => Sec Architecture&Design => Secure Sourcing => Secure Implementation => Sec Testing => Sec Documentation => Sec Certifications => DevSecOps => back to Secure Product. **Post Launch Product Sec:** Secure Product => Secure Deployment&Operation => Sec Maintenance/Patching => Configuration Mgmt => Vuln Mgmt => Information Sharing => Customer Sec Collaboration => Sec Monitoring => Threat Intelligence => Incident&Crisis Handling => Secure End of Life => back to Secure Product. **Foundations:** Cyber Sec Mgmt Sys; Development&Production Sec/Sec Risk Mgmt; Org Culture Awareness&Training/Supply Chain Sec. **Activities w/ Company Development:** Requirements (Requirements Mgmt) => Design (Architecture/Design Reviews/Defense in Depth/Product Composition definition/Procurement) => Implementation (Code Analysis/Reviews/Secure Coding Standards/Hardening/Procurement) => Testing (Verification/Automated Sec Testing/ Penetration Testing/OSS Identification) => Launch (Release Clearance/ Code Signing/Customer Sec Doc.) => **Manufacturing:** Production (Key Provisioning/Logistics) => **Operation:** Issue mgmt (Supported Update/Vuln Mgmt/Incident Mgmt/Obsolete: Decommissioning). **Continuous (full lifecycle):** Threat Modeling; Secure Environment&Infra/Information Sec/ Human Risk Mgmt; Roles&Responsibilities/Training/Sharing/Evangelizing; Risk Mgmt/Governance Definition/Metrics. **SW Bill Of Material (SBOM):** **Why:** trust in digital infra should be proportional to its transparency, lack of it increases cyber risk + dev/procurement/maintenance cost. **Minimum content:** org/person that created artifact, used tool to generate SBOM, timestamp SBOM generation, component name, component version, UUID, relationship w/ other component. **More requirements:** Frequency (update on any change), Depth (all direct+indirect dependencies), Known Unknowns (state if info missing/why), Distribution&Delivery (machine+human readable, accessible to customer), Access Ctrl, Accommodation of Mistakes. **Secure Boot** HW-backed root of trust: each boot stage verifies signature/ crypto key of next stage before executing (Boot ROM => U-Boot SPL => U-Boot => Linux Kernel => Application). **Challenges:** vendor-specific (NDA to access docs), key mgmt (on/off device), key rotation, OSS licences (GPL), 3rd-party app integration. **Supply Chain Risk Mgmt** Applies to IT/OT/IoT. Manages cyber risk from ICT/OT products, services, suppliers, sys integrators, service providers. **Process:** Threats (adversarial: malware/ espionage/disruption; non-adversarial: disaster/poor quality/regulatory) x Vuln (external: supplier interdependencies; internal: unpatched sys, lack of awareness) => Likelihood => Impact => Risk. **Symmetric vs Asymmetric Crypto** **Symmetric:** 1 shared secret key. **key distribution problem:** nb of keys grows w/ square of nb of entities ($n(n-1)/2$). **Asymmetric:** key pair (public/private), solves distribution problem. **Use of Public Key:** 1) decrypt signature to validate signer's identity (signer used private key) 2) encrypt content that only matching private key owner can decrypt (confidentiality). **Digital Signature** Guarantee integrity&authenticity of data. **Sign:** 1) hash message => fingerprint 2) encrypt fingerprint w/ signer's private key => signature, attach to message. **Verify:** 1) recompute hash of received message => fingerprint A 2) decrypt signature w/ signer's public key => fingerprint B 3) compare A=B => valid (intact + authentic). **Certificat X.509** Digital cert to authenticate entity&encrypt messages. Link btwn entity&its public key <= attested by trusted third party. **Content:** Common name (unique name of entity, can be wildcarded; Subject Alt Names = other DNS names covered, Issuer name (chains up to Root CA), Entity public key (algorithm/size), CA signature, Serial Number, Validity, Fingerprints (SHA-256/SHA-1), Key Usages/Extended Key Usages (Srv/Client Auth). **Extensions (v3):** Authority Key ID (CA's key to verify sig), Subject Key ID, Key Usage, CRL Endpoints, Authority Info Access (OCSP/CA Issuers). **Hierarchy:** Root CA (self-signed, top of hierarchy, long validity 10-30yrs, can be stored in browsers/OS) => signs Intermediate CA => signs end-entity cert. **Public Key Infrastructure (PKI)** Set of HW/SW/policies/procedures to create/manage/store/distribute/ revoke cert. **private sym/asym key must be confidential/authentic ; pub key must be authentic!** **Certif Authority (CA):** Publish&renew certif & create revocation lists. Entire trust is based on it. Anyone can become CA (defined by root cert). **Certif Revocation List (CRL):** certif has limited validity period. Revocation if compromised key. Contains list of serial numbers of revoked certif (signed by CA). **Registration Authority (RA):** Manage certif requests: Storing them, verification w/ credential, communicating w/ requesting entity to establish identity/verify compliance, publishing revocation lists. **Validation Authority (VA)** Provide certif verification service. **Certification practice** CA must describe process used to issue certif in document called **Certification Practice Statement**. More CA invests in verifying identity of entity, more secure/expensive certif. **Extended Validation (EV)** most hard to obtain => Verification of legal/ physical entity&operational presence of entity. Verification that entity has rights on required domain. Notarized confirmation of entity&its rights. **Reducing lifespan:** Enhanced sec (limite private key exposition&impact if compromised), encourage automation&best practices adoption. Prepare for post-quantum challenges. **CRL deployment in OT:** host CRL internally, plain HTTP not HTTPS (else checking CRL srv's own cert could itself require CRL = circular dependency), automate generation. **Hard-fail** (reject if can't verify, prioritize sec) **vs Soft-fail** proceed if can't verify, prioritize availability. Air-gapped/segmented OT often can't reach CRL srv live => need offline distribution (preloaded/manually updated CRL). Monitor/alert on revocation infra health (CRL not regenerated, srv unreachable, device

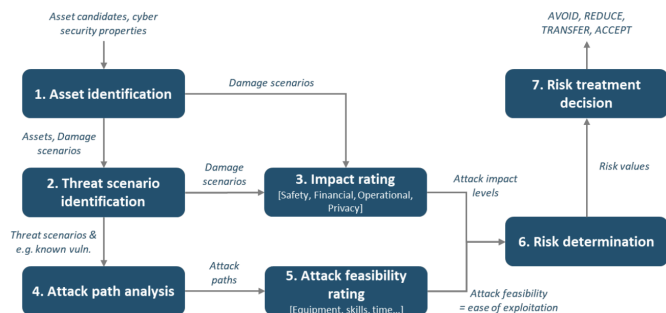
check failures). **OT-specific:** OT protocols (Modbus, OPC UA, DNP3 w/ TLS) have varying support for cert validation/revocation checking, some ignore CRL entirely => test w/ real devices. **IEC 62351-9:** certif mgmt guidance for power sys. Change mgmt in OT more rigid => plan renewals around maintenance windows, validity periods need runway for delayed updates.



IT/OT Sec vs. Product Sec: **IT/OT:** stakeholders=internal actors&suppliers, goals=business continuity/resilience, regulatory=NIS2/GDPR. challenges=standard IT practices vs OT, asset heterogeneity/legacy, patch mgmt. **Product sec:** stakeholders=integrators&end users, goals=product liability, regulatory=legally binding for digital products sold in EU. challenges=integrate cybersec into dev/operation process, transversal to org units, compliance complexity, decommissioning responsibility unclear. **Common:** same foundations, products increasingly connected => policies cross IT/OT/Product domains. **Sec Principle Holistic approach:** tech measure alone often not sufficient => think Technologies/Human factors/Processes together, on top of Risk Mgmt, framed by regulatory framework. **Sec by design:** integrate sec measures&ctrls from beginning of dev. Apply where/when/how it matters. Most efficient way to reduce risk lvl down to acceptable lvl. Keep up-to-date visibility over current threat landscape. **Secure the weakest link:** how to identify it? if vuln affects ctrl, how does it impact overall risk (which risks affected)? most effective way to mitigate once identified? **Defense in depth:** is 1 ctrl enough? which layer mitigates which risk? how many weaknesses acceptable before risk increases?. **Fail secure:** identify essential/safety functions, consider conflict w/ other discipline. **Assume secrets not safe:** treat secret exposure as realistic threat, evaluate impact if compromised, forget sec-by-obscurity, enforce lifecycle ctrls (key rotation/expiration, secure update). **Monitor&audit:** supports forensic readiness, drives integrity/trust in audit data, monitoring = sec measure itself. **Proportionality&Precautionary:** quantify risk to enable proportional response, avoid "one-size-fits-all" (=same sec everywhere), justifies decisions (traceability), balance sec vs constraints (performance/cost/ usability). **Threat analysis&Risk Assessment (TARA)** Defining&prioritizing what must be protected based on risk&threat analysis. What are my key assets&what potential consequences / damages ? What are atck vectors against my assets ? How&on what invest effort to reach reasonable sec posture ? What sec measures for which improvement ? What to monitor for securing continuous acceptable residual risks ? What sec principles are we willing to follow ? Key tool to understand cs risk&support risk-informed decision-making. Mandatory in multiple regulations: products w/ digital elements (EU Cyber Resilience Act, Radio Equipment Directive, Machinery Directive), critical infrastructure (EU NIS2), also medical/automotive,&in Switzerland (ICT minimum, mandatory for gas/energy producers&distributors). Must be integrated into SW Development Life Cycle, as early as possible. Must be challenged&updated, it is living document. **Challenges:** lack of cs competences across orgs, lack of general cs strat leading to inconsistencies (missing initial assumptions&rationales, bias from considering existing protection measures), weak maturity of tooling&SW support, need for stakeholder interactions (interfaces w/ other risk assessments such as quality/functional safety, interfaces btwn IT-Sec/OT-Sec/Product-Sec, **RASIC roles:** Responsible/Accountable/Supportive/Informed/Consultative,&maintenance complexity (risks continuously evolve, vuln considerations must be integrated during operation phase too). **After TARA:** document&implement sec measures against known threat catalog, verify their effectiveness through Verification (did we build it right?)&Validation (did we build right thing?), review TARA after each feature update, context change, new threat, new atck feasibility,/new vuln,&document each accepted/transferred risk for traceability (why it was accepted, to whom&why it was transferred&what must be checked, how it was reduced, how it was avoided). **TARA Process:** 1) **Sys&Assets Definition:** clarify product function/goals, which assets&cs attributes matter if compromised, assumptions about environment&adversarial conditions, architecture (product&sub-sys), communications (dataflows/technologies/inf exchanged), trust boundaries (what is under company's ctrl). 2.a) **Damage scenario, Impact rating and analysis:** is consequence of compromising cs property of an asset (authentication/ integrity/confidentiality/availability). Impact rating uses SFOP categories (Safety/Financial/Operational/Privacy), each rated Severe/Major/Moderate/ Negligible. Analysis must be reproducible/trustable/tailored to use-case. 2.b) **Threat scenario:** identify high-lvl atck scenarios using **STRIDE:**

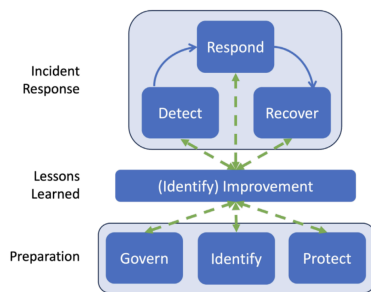
Spoofing (breaks authenticity), Tampering (breaks integrity), Repudiation (breaks non-repudiation), Information disclosure (breaks confidentiality), Denial of service (breaks availability), Elevation of privilege (breaks authorization). **3) Risk values&treatment:** compute risk value, then take risk-based treatment decision (avoid/transfer/mitigate/accept). **2.a) Attack trees** Threat scenarios are analyzed to describe possible attack paths. **Top-down:** attack trees, attack graphs, taxonomy mnemonic-based approaches such as STRIDE, useful in concept&development phases when implementation is not yet available, or when building attack hypotheses. **Bottom-up:** based on output of vuln analysis, used when an implementation is already available, to confirm hypotheses. **Combination:** mix of both approaches. **2.a) Attack feasibility** For each attack path, feasibility is rated High/Medium/Low/Very Low, using one of three methods: **Attack vector-based:** based on predominant attack vector of attack path, basic approach useful for an early-stage assessment. **CVSS-based:** based on exploit metrics group (attack vector, attack complexity, privileges required, user interaction), formula $E = 8.22 \times V \times C \times P \times U$. **Attack potential-based:** elapsed time, specialist expertise, knowledge of item/component, window of opportunity,&equipment. **3) Risk Matrix** risk matrix maps impact lvl&attack feasibility to risk value. **Purpose:** support risk treatment decisions including selection of ctrls, prioritize risks for treatment, report to stakeholders,&monitor risk over time. **Treatment options:** avoid risk (remove risk source), reduce risk (identify sec measures), share/transfer risk (through contracts/insurance), or accept/retain risk. When risk is accepted/transferred, rationale must be documented as cs claim, subject to validation&monitoring.

	Very Low	Low	Medium	High
Severe	2	3	4	5
Major	1	2	3	4
Moderate	1	2	2	3
Negligible	1	1	1	1



TARA Process Review Checklist for evaluating “good job” in threat model documentation. **Completeness:** is all information in STRIDE/attack tree analysis complete, are strongest possible mitigations identified, are gaps understood? **Clarity:** is each threat&mitigation clearly explained for intended audience? **Specificity:** is each element at right lvl of detail? **Traceability:** are relationships btwn components easily traceable, are identifiers consistent¬ duplicated? **Consistency:** does documentation match actual implementation of manufactured device? **Roles&responsibilities:** are they clearly identified when discussing risk? **Assumptions:** are they clearly identified&reasonable? **Rationales:** are decisions justified in enough detail, especially when risk is accepted/transferred? **Contingency Plans (CP)** Identified services provided by essential sys are able to operate w/o excessive interruption. Establish plans/procedures/measures unique to each sys to prevent/recover. **Goals:** Restore normal modes of operation w/ minimal cost&disruption to normal business activities after an adverse event. **CP Type:** Incident Response Planning (IR), Disaster Recovery Planning (DR), Business Continuity Planning (BC), Crisis Mgmt Planning (CM). **Cost Balance Point:** Intersection btwn Cost to Recover&Cost of Disruption. **Incident** adverse event beginning to attack org against its cs assets, which has realistic chance of success to threaten CIA of information assets/ other resources. **Triage (event to incident):** Event of Interest (detected via SIEM/IDS/IPS/Firewalls/Access Ctrl/threat intelligence) is checked for indicators of compromise&sorted into one of four outcomes (only last one being true incident): **Natural Causes** => BCP; **Accidental** => Safety/Training/Procedural fix; **Sys Failure** => Maintenance&Recovery; **Intrusion/Unauthorized Access/Malware** => Computer sec Incident. **Incident Response Plan (IRP)** Preparation for/detection of/reaction to/recovery from incident (Event => Adverse Event => Incident). **Incident Response Planning Team (IRPT):** led by CISO/cs manager, w/ heavy presence of cs/IT/OT people/non-technical members. **Incident Response Policy:** contain statement of mgmt commitment, purpose/obj of policy, scope (to whom&what it applies under what circumstances), definition of cs incidents/related terms, organizational structure/definition of roles, responsibilities/ lvls of authority, requirement to report certain types of incidents, prioritization/severity ratings of incidents, performance measures, reporting/contact forms. **Incident Response Plan elements:** mission, strategies&goals, senior mgmt approval, approach to incident response, communication strategies, metrics for measuring incident response, roadmap for maturing incident response. **Incident Response Plan procedures:** set of actions to take during incident/after incident is contained/before incident even occurs.

CERT vs CSIRT: CERT (Computer Emergency Response Team) takes proactive measures to prevent incidents/enhance sec, works at national/organizational lvl, focus prevention/preparedness, favorize communities of practice for knowledge sharing. CSIRT (Computer/Cyber Sec Incident Response Team) reacts to sec incidents w/i an org, typically focused on specific org/sector, focuses immediate response/remediation, builds internal capabilities to enhance organizational sec awareness. **CSIRT Liaison:** liaison btwn org&CSIRT, it allows anyone to report suspicious activity. **Incident Response Actions:** detection of incident that is underway¬ify CSIRT, reaction of CSIRT to incident by activating IR plan&selecting appropriate response strat, recovery phase where CSIRT works w/ rest of company to restore normal operations. **Incident Reporting Obligation (CH)** For critical infrastructure, under Swiss CS Ordinance, cyberattack must be reported w/i 24 hours of detection (14 days to complete report if information is missing), via Cyber Sec Hub (CSH) to the NCSC. report must include information on attacker, detection&attack timestamps, whether attack is linked to blackmail/coercion&whether it was reported to police, severity of damage to CIA&effects on org’s functioning. **Disaster Recovery Plan (DRP)** Prepares for&recovers from natural/man-made disasters. Recovers/purchase/replace assets from appropriate sources. Reestablishes functional assets at primary site/new one. **Business Continuity Plan (BCP)** Ensures that critical business activities can continue if disaster occurs, by relocating core functions to temporary facility. Managed by CEO/COO,&activated shortly after Disaster Recovery Plan. **Crisis Mgmt Plan (CMP)** Focuses protecting human health/welfare, managing crisis itself, supporting employees/guests, keeping public informed, communicating w/ major stakeholders. **CP Methodology 1)** Form CPMT **2)** Develop CP policy **3)** Conduct BIA **4)** Form subordinate planning teams **5)** Develop subordinate planning policies **6)** Integrate BIA **7)** Identify preventive ctrls **8)** Organize response teams **9)** Create response strategies **10)** Develop subordinate plans **11)** Ensure testing, training&exercises **Contingency Planning Mgmt Team (CPMT) Responsibility:** Obtaining commitment from senior mgmt, Managing&conducting overall process, Writing master CP document, Conducting BIA, Organizing/staffing subordinate teams (both planning/response teams), Providing guidance to&integrating work of subordinate teams. **CP Policy** Document that mandate to do CP (above IR/DR/BC/CM plans). **Content:** introductory statement on why CP matters, scope/purpose of CP, call for periodic risk assessment&BIA, definition of major CP components, identification of individuals responsible (clearly defined roles), guidance for selecting recovery options/BC strategies, requirement to train/exercise/test plans, identification of key laws/standards/regulations, call to regularly challenge org assumptions. **Business Impact Analysis (BIA)** Assess mission/business process&recovery criticality, Identify resource requirements/recovery priorities => Use time criticality of functions/processes to guide prioritization. **Recovery Point Objective (RPO):** maximum acceptable lvl of data loss following unplanned event (time btwn last consistent backup&disaster). **Recovery Time Objective (RTO):** time business process could be unavailable before business operations are significantly impaired. **Maximum Tolerable Period Of Downtime (MTPOD):** duration after which org viability would be irrevocably threatened if product/service delivery cannot be resumed. **Inputs to BIA data collection:** Risk assessment, IT/OT applications/logs, audit/financial reports. **BIA in OT:** fails when lack of cross-functional input (engineering/operations/OT maintenance), failure to capture indirect dependencies, lack of understanding that IT time-based assumptions do not apply to OT (an RTO multiple hours may be fine in IT but 5 minutes downtime can have significant impact on OT). Modern OT BIA must identify critical processes&functions, not just sys, map technical dependencies/operational tolerances, quantify cross-site impacts for multi-site operations, incorporate recovery thresholds informed by real scenarios, not just SLAs. **BIA Content:** ID/Business Activity/Activity Owner/Category/Area of Impact/RTO/RPO/MTD/Priority/Recovery Approach/Resources needed/References **NIST CS Framework** Identify understand cs risks **Protect** develop/implement safeguards to guarantee services **Detect** develop/implement activities to identify occurrence of cs event **Respond** develop/implement activities to take action regarding detected event **Recover** develop/implement appropriate plan to maintain resilience&restore capability disrupted by cs event. **Govern** org’s cs risk mgmt strat, expectations&policy are established, communicated&monitored, on top of Identify/Protect/Detect/Respond/Recover. **NIST Handling Checklist** classic incident handling lifecycle, after preparation. **Detection&Analysis:** determine whether incident occurred (analyze precursors/indicators, look for correlating information, perform research, document investigation&gather evidence as soon as incident is suspected), prioritize handling based on impact, report incident to appropriate internal/external parties. **Containment, Eradication,&Recovery:** acquire/preserve/secure/document evidence, contain incident, eradicate it (mitigate exploited vuln, remove malware, repeat detection steps if more affected hosts are discovered), recover from incident (return affected sys to operationally ready state, confirm they function normally, implement additional monitoring for future related activity if needed). **Post-Incident Activity:** create follow-up report, hold lessons-learned meeting.



Sec Operations Center (SOC) Focal point for sec operations/cyber network defense, gives holistic situational awareness of org's sec posture. **Activities:** asset inventory, routine maintenance/preparation, incident response planning, regular testing, continuous monitoring/log mgmt, threat intelligence/detection, incident response, recovery/remediation, post-mortem/refinement, compliance mgmt. Can be externalized. **vs CSIRT/PSIRT/ISAC:** SOC must handle monitoring/detection&event analysis; CSIRT must handle incident report acceptance, incident analysis, mitigation/recovery&incident coordination; PSIRT (Product Sec Incident Response Team) must handle vuln report intake, analysis, coordination, disclosure&response; an ISAC (Information Sharing&Analysis Center) must handle data acquisition, analysis/synthesis&communication for situational awareness. **Regulation > Standards > Guidance Regulation:** legally binding, usually bound to specific industry/geographic national/international area (NIS, GDPR). **Standards&Norms:** state-of-the-art definition, consensus-based document, not mandatory unless contractual (ISA/IEC 62443, ISO/IEC 27000); typical product, process&mgmt sys certifications are based on them. **Guidance&Best Practices manual:** more "dynamic" because it is outside standardization scheme, supportive document w/ tangible inputs (NIST documents, ENISA). **IEC 62443 vs ISO 27001** Complementary, not competing. **IEC 62443:** product/IACS, OT. **ISO 27001:** org's own operations, IT. **ISA/IEC 62443** International series of standards that address cs for operational technology in automation&ctrl sys. Compromise of physical sys can lead to risk of human life or safety, damage to machinery, financial impact,&harm to environment. **Scope:** any SW/HW/personnal/policies involved/have influence over safety/sec/reliability of Industrial Automation&Ctrl Sys (IACS) operations. **Dimensions:** (holistic approach)Technologies, Processes, Human factors from any stakeholder perspective. **Roles:** Asset Owner (accountable for&operates IACS), Maintenance Service Provider (maintains it), Integration Service Provider (commissions/validates&designs/deploy automation solution), Product Supplier (develops&supports components/products, independent of IACS environment). **Key Principles:** Network segmentation into Zones&Conduits, Defense in depth, Sec/Maturity lvl, **IEC 62443 - Zones&Conduits** Modern architectures use **Zones** instead of Purdue lvl (e.g. Enterprise Network, Industrial/Enterprise DMZ): physical/logical groupings of assets sharing common sec requirements, isolating critical ctrl sys components. **Conduits:** special type of zone, controlled communication paths between zones (e.g. via firewall/managed switch), logically organizing the flow of information w/i&external to a zone. **IEC 62443 - Defense in Depth** From outer to inner. **ICS/IACS-specific policy:** standards/procedures/training/BCP/DRP. **Physical Sec:** guarding/access ctrl. **Perimeter Sec:** firewalls/DMZ/VPN/IDS/IPS. **Network Sec:** zones&conduits/network segmentation/internal DMZ/firewalls. **Equipment Safety:** patch mgmt/hardening/port ctrl/continuous monitoring/audit. **Application Sec:** access ctrl/authentication/pwd mgmt/update mgmt. **Data Sec:** secure communications/authentication/terminal sec. **ISA/IEC 62443 Structure** Each aimed at different stakeholders. **Part 1 - General** (for any stakeholder): 1-1 Concepts&models, 1-2 Master glossary of terms&abbreviations, 1-3 System sec compliance metrics, 1-4 IACS sec lifecycle&use-case. **Part 2 - Policies&Procedures** (for asset owners&service suppliers): 2-1 Sec program requirements for IACS asset owners (=CSMS), 2-2 IACS Sec Protection Ratings, 2-3 Patch mgmt in IACS environment, 2-4 Sec program requirements for IACS service providers, 2-5 Implementation guidance for IACS asset owners. **Part 3 - System** (for asset owners&system integrators): 3-1 Sec technologies for IACS, 3-2 Sec risk assessment for system design, 3-3 System sec requirements&sec lvls. **Part 4 - Component/Product** (for component/product suppliers): 4-1 Product sec development life cycle requirements, 4-2 Technical sec requirements for IACS components. Documents are also tagged as either Process requirements (maturity lvl) or Technical requirements (sec lvl). **IEC 62443-2-1 & 2-4** 2-1: defines the elements needed to establish a Cyber Security Management System (CSMS) for IACS&provides guidance on how to develop them. 2-4: defines the security capabilities to be supported by integration&maintenance service providers' security programs; asset owners use it to check if a provider's program covers their needs, before issuing a Request for Quote (RFQ) with a Statement of Work (SOW) defining security policies/requirements. Asset owner usually doesn't specify HOW a requirement is implemented (e.g. backup/restore, that's the provider's job) but may set constraints (e.g. password timeout values). Supplier capability evaluated via CMMI-SVC-based maturity lvls (Initial/Managed/Defined-Practiced/Improving). **Integration activities:** analyze the physical/electrical/mechanical environment to control, develop the Automation Solution architecture, define external network

connections, install/configure/patch/backup/test before handover, get asset owner approval. **Maintenance activities** (after handover, short&recurring): patching/AV updates, equipment upgrades, component/sys migration, change mgmt, contingency plan mgmt. **IEC 62443-2-3 Patch Mgmt Planning:** develop business case (secure funding/resources from senior mgmt) => establish/assign roles&responsibilities => establish testing environment => establish backup/restore infrastructure => provide input to procurement guidelines. **Operating:** change mgmt (patching follows change ctrl), vuln awareness, outage scheduling, sec hardening (removes unneeded SW, reducing applicable patches), inventory&data maintenance (track vuln/patch status), procuring new devices, reporting&KPIs. **IEC 62443-3-2 Risk Assessment** Engineering measures guiding an org through assessing risk of particular IACS and applying countermeasures to reduce it to tolerable lvl. **Initial risk assessment:** identify Sys under Consideration => perform initial cs risk assessment => partition the SuC into zones&conduits => check whether initial risk exceeds tolerable lvl. **Detailed risk assessment** (if it does): identify threats => identify vuln => assess the consequence/impact => determine likelihood => determine risk => compare to tolerable risk => identify additional countermeasures if needed. Then document cs requirements and get asset owner's approval. **IEC 62443-3-3 Foundational Requirements (FR)** Technical requirements (sys level in 3-3, derived from the 3-2 risk assessment; redefined at component level in 4-2), catalogued into 7 dimensions. **1) Identification&Authentication Ctrl (IAC):** identify/authenticate all users (human/SW/device) before access. **2) Use Ctrl (UC):** enforce&monitor the assigned privileges of an authenticated user. **3) Sys Integrity (SI):** protect against unauthorized manipulation. **4) Data Confidentiality (DC):** protect confidentiality of info in transit&storage. **5) Restricted Data Flow (RDF):** segment via zones/conduits to limit unnecessary data flow. **6) Timely Response to Events (TRE):** notify authorities, report evidence, take timely corrective action on violations; how incident response/recovery is integrated into the framework. **7) Resource Availability (RA):** ensure availability against degradation/denial of service. **IEC 62443-4-1 Secure Development Life Cycle (SDLC)** 8 practices organized around central Defense-in-Depth strat: Sec Mgmt (SM), Specification of sec requirements (SR), Sec by design (SD), Secure implementation (SI), Sec verification&validation testing (SVV), Mgmt of sec-related issues (DM), Sec update mgmt (SUM), Sec guideline (SG). **Threat Model Hints:** product suppliers must perform risk assessment at product lvl, via threat model covering flow of categorized information, trust boundaries, processes, data stores, internal/external communication protocols, externally accessible physical ports, circuit board connections, potential attck vectors, potential threats&severity, mitigations per threat, and external dependencies. **IEC 62443-4-2 Component Requirements** Segmented into 2 categories: Common Component Sec Constraints (CCSC) & the same 7 FR as 3-3, redefined at component level (see Foundational Requirements). **CCSC:** 1) support of essential functions (benefit-risk analysis between safety&sec determines what can be sacrificed in degraded mode), 2) compensating countermeasures (if requirement can't be met natively, external countermeasure applied by sys must be documented), 3) least privilege ("DENY ALL" by default, then create roles w/ adequate rights), 4) secure development process (must follow 4-1 SDLC, "you cannot provide sec capabilities of product w/o ensuring its secure development"). **Certification rule:** SL-Achieved is a vector across the 7 FR, but certification can only be claimed at the lowest SL achieved among them, e.g. a component scoring [4,1,3,2,4,3,2] can only be certified SL1 (the weakest link). **Component types for tailored requirements:** SAR (SW Application, e.g. a SW module), EDR (Embedded Device, e.g. PLC/IED), HDR (Host Device, e.g. operator workstation/data historian), NDR (Network Device, e.g. switch/VPN terminator/gateway). **ISA/IEC 62443 Sec Level (SL)** Same scale on both sys&component lvl, used to compare cs maturity of components/sys&increase w/ impact on safety/exposure to threats/significance of vuln/value of assets to protect. **SL0:** not implemented. Per level (Target/Skills/Motivation/Means): **SL1,** prevent mistakes: Misconfiguration/No awareness/Confusion/No objective. **SL2,** prevent hacking: No sec measures implemented, hacker/Basic/Low/Straightforward. **SL3,** prevent sophisticated hacking: Only moderate sec measures implemented, high-level hacker/Industrial-specific/Average/Intentional. **SL4,** prevent state-sponsored hacking: Economical damage/Highly sophisticated/High/Aggressive. **3 sub-levels:** SL-Target (desired lvl for zone/conduit, determined via cs risk assessment), SL-Capability (lvl component/sys can provide natively when properly configured, w/o compensating measures), SL-Achieved (actual lvl for particular environment/zone/conduit, measured once environmental design is in place). **ISA/IEC 62443 Maturity Level (ML)** Measures how professional organization is. Defines benchmark required to be met by requirements in those two standards; service providers&asset owners must identify maturity level associated w/ implementation of each requirement, each lvl being progressively more advanced. **ML1 (Initial):** capability to perform service w/o documented process, poorly controlled. **ML2 (Managed):** capability to perform in formal documented characterized process, w/ evidence of expertise&trained personnel, practices are documented. **ML3 (Defined/Practiced):** capability including evidence of practicing process **ML4-5 (Improved):** capability including demonstration of continuous improvement.